Кейс 04. ИСП РАН / GitLab: положительное основание для условного мониторинга

Срез дополнительного набора: 2026-10-24T19:13:42+00:00. Горизонт наблюдения — до 2026-11-23. Исходный снимок на 374 публикации и корпус человеческой разметки не меняются. Кейс поставляется отдельным snapshot.json.gz и не выдаётся за часть прежнего среза.

Вопрос и решение

Достаточно ли свежих публичных оснований повысить приоритет проверки обновления конкретного GitLab-сервиса ИСП РАН?

Решение текущего среза: conditional_monitoring_candidate. Повысить приоритет внутренней проверки версии и обновления; это условная гипотеза мониторинга. Совпадение продукта и свежего бюллетеня даёт конкретную задачу проверки. Уязвимая версия, эксплуатация сервиса и будущая атака не установлены. Решение не означает, что институт следует объявить следующей целью.

Проверяемая цепочка

Официальная страница лаборатории ИСП РАН перечисляет GitLab и GitLab CI/CD в своём стеке и ссылается на собственный проект Utopia EDA на gitlab.ispras.ru. Дата публикации этого описания неизвестна; сегодняшняя дата ему не присваивается.

Отдельно 24.10.2026 обычный GET публичной страницы списка проектов вернул HTTP 200. В HTML указаны realm=self-managed, deployment_type=self-managed и context_generated_at=2026-10-24T19:09:54.392Z. Это наблюдение текущего сервиса, а не сканирование, запрос версии через служебный endpoint или эксплуатация. Полный исходный HTML не сохранялся; в evidence.json приведены время наблюдения, короткий пересказ и SHA-256 полученного ответа. Хеш краткого сохранённого текста указан отдельно. Он не является хешем всей веб-страницы.

Бюллетень самого GitLab от 21.10.2026 описывает CVE-2026-110264 в CE/EE и срочные исправления для самостоятельно управляемых установок. Использование конкретного сервиса и область бюллетеня проверены раздельно. В этой цепочке нет сообщения об эксплуатации сервиса института.

Даты, версии и источники

Давность наблюдения сервиса на срезе: 0 дней; бюллетеня: 3 дней. Пороги очереди — 180 и 30 дней; они экспертные, прогнозная полезность не измерена. Дата наблюдения хранится как observed_day с основанием public_service_observation. У двух недатированных страниц published_at=null; для бюллетеня известен календарный день, но точное время публикации не выдумано.

Источник: manual_ispras_lab_reference · Роль: organization_to_service_reference · Дата

публикации: дата публикации неизвестна · ID и первоисточник: 04710733d146e3fa09f10e1b

Источник: manual_ispras_service_observation · Роль: dated_public_service_observation · Дата публикации: дата публикации неизвестна · ID и первоисточник: 8916d205ea89776647d4cb41

Источник: manual_gitlab_security_notice · Роль: vendor_security_notice · Дата публикации: 2026-10-21 · ID и первоисточник: fb266c528f407e357a6445c1

Исправленные релизы перечислены по веткам: 18.11.13, 19.0.10, 19.1.9, 19.2.9, 19.3.6, 19.4.3, 19.5.1. Точные диапазоны перенесены из первичного бюллетеня в метаданные. Одно общее сравнение «версия меньше 19.5.1» здесь неверно. Состояние GitLab.com и GitLab Dedicated нельзя переносить на отдельный self-managed сервис. Установленная версия остаётся неизвестной.

Что ограничивает вывод

- Номер установленной версии и состояние исправления неизвестны.

- Обычная публичная страница не доказывает достижимость уязвимого обработчика.

- Атака на институт, эксплуатация его сервиса и интерес конкретной группировки не установлены.

- Описание лаборатории недатировано; дата 24.10.2026 относится к отдельному наблюдению сервиса.

- Описание лаборатории и её сервис — одна группа источников, не два независимых подтверждения.

- Наблюдение касается одного публичного сервиса; вывод не переносится на весь институт.

- В кейсе ручные пересказы и проверка ассистентом; независимая экспертиза не заявляется.

Источник института и его публичный сервис относятся к одной группе ispras. Бюллетень относится к группе gitlab_vendor: это независимый издатель, но он подтверждает область уязвимости продукта, а не состояние установки института. Связь с организацией ограничена описанной лабораторией и конкретным сервисом.

Следующее действие и условия пересмотра

- Владельцу системы: сверить фактическую версию с бюллетенем и подтвердить установку исправления.

- Аналитику: отслеживать официальные сообщения о версии, обновлении и применимости CVE.

- Проверять журналы по правилам разработчика только внутри своего разрешённого контура.

Подтверждённая исправленная версия исключает соответствующую гипотезу. Отмена подтверждения использования или области CVE снимает доказательное основание кейса. Старое наблюдение или старый бюллетень выводят запись из текущей условной очереди.

Новое официальное сообщение о событии рассматривается отдельно, без автоматического приписывания ему этой CVE.

Воспроизведение

В отдельной базе выполнить python3 scripts/build_monitoring_case.py. Скрипт использует короткие сохранённые первичные материалы из examples/ispras_gitlab_case.json и фиксированный AS_OF. Повторный seed не перезаписывает компании, публикации и существующие проверки, в том числе отменённые. Повторный импорт — не новая ручная проверка источника: сохраняется исходное время проверки ассистентом и отдельно фиксируется время импорта.

Готовый дополнительный снимок можно восстановить стандартным app.review_snapshot.restore_snapshot и пересчитать app.monitoring_case.analyze на дате из snapshot_manifest.json. decision.json, evidence.json и score_snapshot.json содержат решение, происхождение и отдельные экспертные индексы. graph_view.html показывает подграф, graph.cypher — путь в Neo4j. Подграф не добавляет стрелку атаки на организацию. Контент — ручные краткие пересказы с открытыми ссылками, не автоматическая выгрузка первоисточников.

Ссылки на первоисточники

04710733d146e3fa09f10e1b: https://education.at.ispras.ru/hwverification

8916d205ea89776647d4cb41: https://gitlab.ispras.ru/explore/projects

fb266c528f407e357a6445c1: https://docs.gitlab.com/releases/patches/patch-release-gitlab-19-5-1-released/